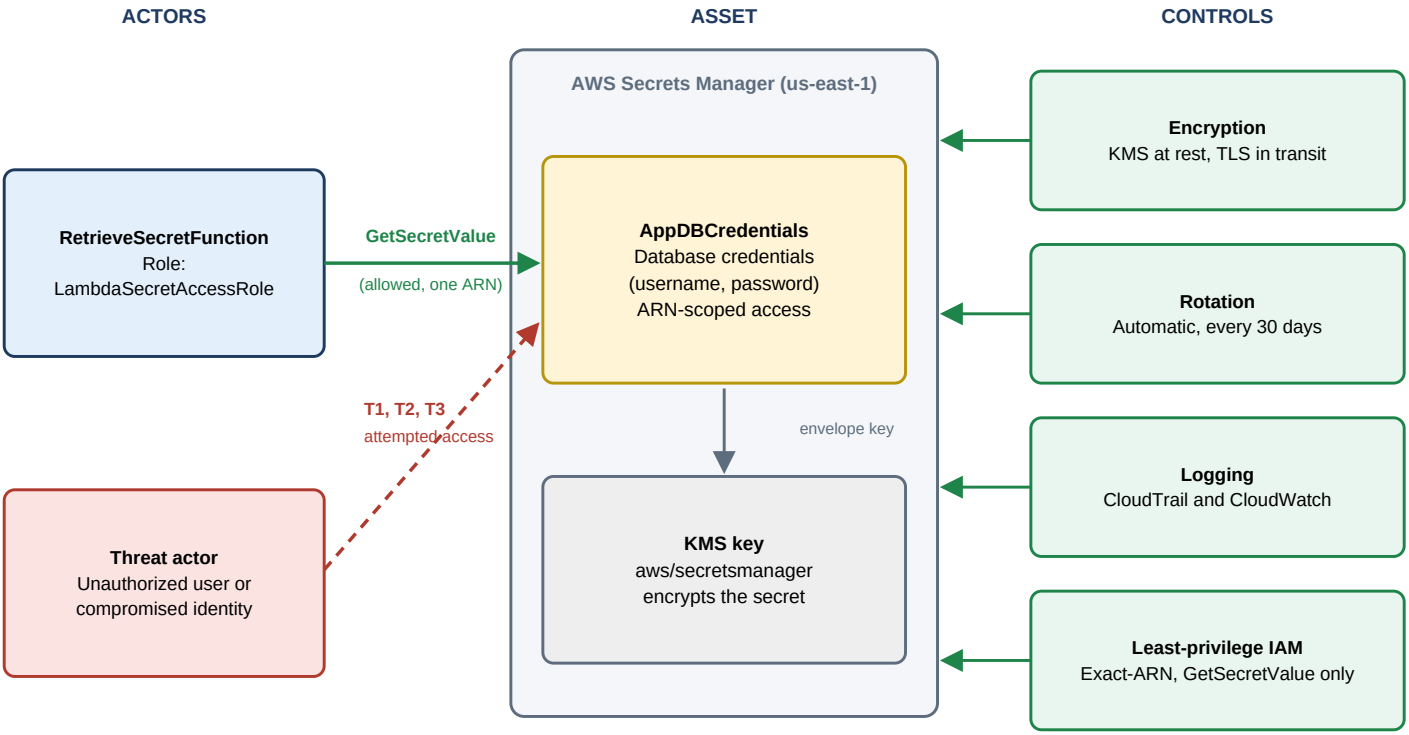
# Threat Model and Risk Matrix: Database Credentials in AWS Secrets Manager

Week 4, Task 14 | Phase D: Secret Rotation & Threat Modeling | Titilayo Yusuf | 27 October 2026

## 1. Threat model diagram

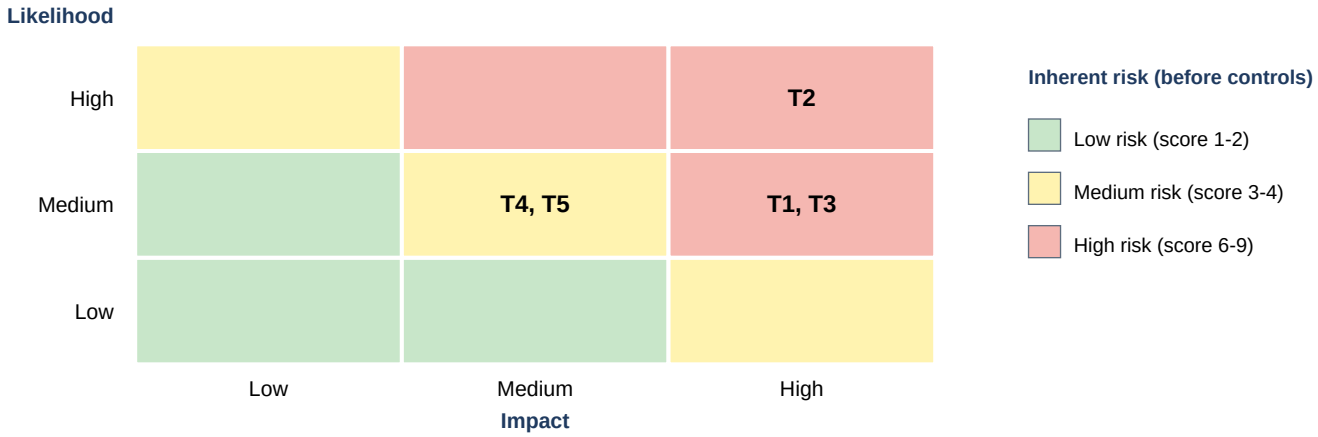



Green arrows show the permitted path. The red dashed arrow shows attempted unauthorized access (threats T1 to T3). Controls on the right protect the asset from every direction.

## 2. Threat register and control mapping

| ID | Threat | Key controls | Inherent (L x I) | Residual (L x I) |
|---|---|---|---|---|
| T1 | **Unauthorized access to the secret.** A stolen or compromised identity calls GetSecretValue. | Exact-ARN policy, KMS encryption, CloudTrail logging | 2 x 3 = 6 High | 1 x 3 = 3 Medium |
| T2 | **Misconfigured IAM role.** Wildcard resources or extra actions let the role read other secrets. | Exact-ARN inline policy, GetSecretValue only, no managed policies on the role | 3 x 3 = 9 High | 1 x 3 = 3 Medium |
| T3 | **Credential exposure through code or logs.** Hardcoded or printed password. | Runtime retrieval, handler returns username only, log check, rotation | 2 x 3 = 6 High | 1 x 2 = 2 Low |
| T4 | **Stale long-lived credential.** An unrotated password stays valid after a leak. | Automatic 30-day rotation, AWSPREVIOUS label for safe cutover | 2 x 2 = 4 Medium | 1 x 2 = 2 Low |
| T5 | **Undetected misuse.** No audit trail of who read the secret. | CloudTrail records every call, CloudWatch holds function logs | 2 x 2 = 4 Medium | 1 x 2 = 2 Low |

## 3. Risk matrix (likelihood vs impact)




Score = likelihood x impact, each rated 1 (low) to 3 (high). Ratings are qualitative judgments for this lab environment. The matrix plots inherent risk; the residual column above shows the expected risk after the controls are applied.

## 4. How rotation reduces credential exposure

Automatic rotation limits how long a leaked credential stays useful, because the value an attacker copied stops working at the next rotation. It removes dependence on people remembering to change passwords, and the AWSCURRENT and AWSPREVIOUS staging labels let applications keep working during the switch. Each rotation is also recorded in CloudTrail, so changes to the credential are visible. Together with encryption and logging, rotation turns a leak from a long-term compromise into a short-lived one.